

Annual Compliance Report to Competent Authority

Document ID	Version	Owner	Effective Date	Framework	Classification
[DORA-REP-001]	1.0	[Chief Compliance Officer / DORA Programme Owner]	[DD MMM YYYY]	Digital Operational Resilience Act	Confidential - Regulatory Submission

Purpose

This Annual Compliance Report provides the designated competent authority with a consolidated overview of [Organisation Name]'s compliance with the Digital Operational Resilience Act for the reporting period stated below.

The report summarises the organisation's digital operational resilience posture, key governance activities, ICT risk management outcomes, material incidents, resilience testing, third-party ICT risk management, remediation progress, and planned improvements. It is intended to demonstrate that [Organisation Name] maintains appropriate arrangements to identify, assess, prevent, detect, respond to, recover from, and learn from ICT-related disruption affecting financial services, customers, counterparties, and market confidence.

This report has been prepared for regulatory reporting purposes and is supported by underlying evidence retained by the relevant control owners, including risk assessments, incident records, testing results, committee minutes, supplier oversight records, audit reports, and remediation tracking.

Reporting Period & Scope

Reporting Period

Item	Details
Reporting period covered	[Start Date] to [End Date]
Date of report approval	[DD MMM YYYY]
Approved by	[Board / Management Body / Executive Committee Name]
Date submitted to competent authority	[DD MMM YYYY]
Reporting entity	[Legal Entity Name]
Registered office	[Address]
Competent authority	[Authority Name]
Primary regulatory contact	[Name, Role, Email, Telephone]

Organisational Scope

This report covers the ICT and digital operational resilience arrangements applicable to the following business areas, legal entities, functions, and locations.

Scope Area	Included	Notes
Legal entities	Yes	[List entities or reference group structure]
Regulated activities	Yes	[Describe regulated financial services in scope]
Critical or important functions	Yes	[List or reference register of critical or important functions]
Internal ICT services	Yes	Includes infrastructure, applications, networks, end-user computing, identity services, monitoring, backup and recovery capabilities
Cloud and outsourced ICT services	Yes	Includes services supporting critical or important functions and material business processes

Scope Area	Included	Notes
Third-party ICT providers	Yes	Includes direct providers, material subcontracting where known, and key ICT supply chain dependencies
Branches and locations	Yes	[List key jurisdictions / locations]
Group shared services	[Yes/No]	[Describe reliance on group ICT, security operations, risk management, procurement, or resilience functions]
Non-production systems	Partial	Included where relevant to resilience testing, change management, or security exposure

Systems and Services in Scope

The following systems and services were treated as priority ICT assets due to their relevance to critical or important functions, customer impact, regulatory reporting, financial processing, security monitoring, or recovery obligations.

System / Service	Business Function Supported	Criticality	Hosting Model	Primary Owner
[Core Banking / Trading / Payments Platform]	[Function]	Critical	[On-premises / Cloud / Hybrid]	[Owner]
[Customer Portal / Mobile Application]	[Function]	High	[Cloud / Hybrid]	[Owner]
[Identity and Access Management Platform]	Enterprise access control	Critical	[Cloud / On-premises]	[Owner]
[Security Monitoring Platform]	Detection and response	High	[Managed service / Internal]	[Owner]
[Data Warehouse / Regulatory Reporting Platform]	Reporting and analytics	High	[Cloud / On-premises]	[Owner]
[Backup and Recovery Platform]	Resilience and recovery	Critical	[Hybrid]	[Owner]

Scope Limitations and Assumptions

The following limitations or assumptions applied during report preparation:

Limitation / Assumption	Impact	Management Response
[Example: One third-party assurance report was pending at the reporting date]	Limited confirmation of current control operation for [provider/service]	Interim review performed using contractual attestations, service reviews, incident history, and prior assurance evidence
[Example: New system implemented late in the reporting period]	Limited operational history available for trend analysis	Included in post-implementation risk assessment and resilience testing plan for next period
[Example: Group-level service dependency]	Reliance on group control evidence	Evidence obtained from group control owner and reviewed by local accountable function

Executive Summary

During the reporting period, [Organisation Name] continued to strengthen its digital operational resilience framework across ICT governance, risk management, incident reporting, resilience testing, third-party oversight, and executive accountability.

Overall, the organisation has established a structured and operational compliance framework for DORA implementation. Key governance arrangements are in place, including defined management accountability, ICT risk ownership, reporting to senior governance bodies, maintenance of critical asset and service inventories, incident classification and escalation processes, resilience testing activity, and oversight of ICT third-party providers.

The annual assessment identified that the organisation is broadly aligned with DORA expectations, with several areas requiring continued improvement. The most significant improvement themes relate to enhancing the completeness of ICT dependency mapping, strengthening exit and concentration risk analysis for material ICT third-party providers, improving evidence consistency for resilience testing, and reducing remediation ageing for selected ICT risk actions.

No ICT-related incident during the reporting period resulted in confirmed prolonged unavailability of a critical or important function beyond approved tolerance levels. [Number] ICT incidents were assessed under the organisation’s regulatory impact criteria, of which [Number] were classified as major and reported to the competent authority within applicable timelines. Lessons learned activities were completed for all major incidents and tracked through the ICT risk and resilience action plan.

Resilience testing was performed across critical systems, including vulnerability assessments, scenario testing, business continuity exercises, disaster recovery tests, cyber response simulations, and targeted technical assessments. Testing identified [Number] high-priority findings, of which [Number] were closed by the end of the reporting period and [Number] remain under active remediation.

Third-party ICT risk management remained a key focus area. The organisation maintained a register of ICT third-party arrangements, reviewed contracts supporting critical or important functions, conducted due diligence and ongoing monitoring, and escalated material provider risks to the relevant governance bodies. Further work is planned to improve mapping of subcontracting dependencies, strengthen exit planning evidence, and enhance concentration risk metrics.

Overall Compliance Assessment

Assessment Area	Status	Summary
Governance and accountability	Largely effective	Roles, committees, reporting lines, and management oversight are established; additional board-level metrics will be introduced
ICT risk management	Largely effective	Core processes are operating; improvement required in dependency mapping and risk acceptance evidence
ICT asset and service inventory	Partially effective	Key assets recorded; completeness and linkage to business services require enhancement
Incident management and reporting	Effective	Classification, escalation, communication, and reporting processes operated during the period
Digital operational resilience testing	Largely effective	Annual testing performed; consistency of evidence and retesting discipline to be improved
ICT business continuity and recovery	Largely effective	Recovery arrangements tested for priority systems; improvements required for cross-provider recovery scenarios
ICT third-party risk management	Partially effective	Register and oversight in place; enhancement required for concentration, subcontracting, and exit analysis
Information sharing and threat intelligence	Developing	Threat intelligence used operationally; formal sharing arrangements remain limited
Training and awareness	Largely effective	Targeted training delivered; additional role-based training planned for incident and supplier owners
Remediation governance	Largely effective	Action tracking in place; ageing and dependency-related delays require closer executive attention

Key Metrics for the Reporting Period

Metric	Result	Prior Period	Trend
ICT risks recorded in enterprise risk register	[Number]	[Number]	[Improving / Stable / Deteriorating]
High or critical ICT risks open at period end	[Number]	[Number]	[Improving / Stable / Deteriorating]
Major ICT-related incidents reported to authority	[Number]	[Number]	[Improving / Stable / Deteriorating]

Metric	Result	Prior Period	Trend
Total ICT incidents logged	[Number]	[Number]	[Improving / Stable / Deteriorating]
Critical or important functions mapped to supporting ICT assets	[Percentage]%	[Percentage]%	[Improving / Stable / Deteriorating]
Critical ICT systems subject to resilience testing	[Percentage]%	[Percentage]%	[Improving / Stable / Deteriorating]
Critical ICT third-party providers reviewed	[Percentage]%	[Percentage]%	[Improving / Stable / Deteriorating]
Overdue high-priority remediation actions	[Number]	[Number]	[Improving / Stable / Deteriorating]
Staff completion of ICT resilience training	[Percentage]%	[Percentage]%	[Improving / Stable / Deteriorating]

Management Conclusion

Management considers that [Organisation Name] has made substantive progress in embedding DORA-aligned operational resilience practices. The organisation has not identified any unresolved condition that would indicate a systemic inability to manage ICT risk or continue critical or important functions within approved recovery objectives.

The improvement plan set out in this report is being actively governed through [Committee Name], with progress reported to [Board / Management Body Name]. Priority actions have been assigned to accountable owners with target completion dates, funding where required, and measurable outcomes.

Methodology

Assessment Approach

The annual compliance assessment was performed using a risk-based methodology designed to evaluate whether the organisation's digital operational resilience arrangements are designed appropriately, implemented effectively, and operating in practice.

The assessment considered both design effectiveness and operating effectiveness across governance, ICT risk management, incident reporting, testing, third-party risk management, business continuity, recovery, and remediation governance.

The methodology included:

- Review of approved governance documents, including policies, standards, procedures, committee terms of reference, risk appetite statements, and reporting packs.
- Interviews and walkthroughs with accountable executives, ICT risk owners, security operations, incident management, business continuity, procurement, legal, compliance, internal audit, and key business service owners.
- Sampling of ICT risks, incidents, third-party reviews, resilience tests, access controls, vulnerability records, change records, and remediation actions.
- Review of management information provided to governance forums.
- Assessment of registers and inventories, including ICT assets, critical or important functions, third-party providers, contracts, incidents, risks, and resilience testing plans.
- Validation of selected evidence against system records, ticketing tools, governance minutes, supplier reports, and assurance documentation.
- Review of prior-period findings and closure evidence.

- Consideration of internal audit results, external audit observations, regulatory correspondence, penetration test reports, and independent assurance activities.

Evidence Sources

Evidence Category	Examples Reviewed
Governance records	Board papers, risk committee minutes, management attestations, policy approvals, committee reporting packs
ICT risk records	ICT risk assessments, control self-assessments, risk acceptances, risk appetite metrics, issue logs
Asset and dependency records	Configuration management data, application inventory, service maps, critical function mapping, data flow records
Incident records	Incident tickets, major incident reports, regulatory notification records, communications logs, post-incident reviews
Testing evidence	Vulnerability scans, penetration test reports, disaster recovery test results, scenario exercises, tabletop outputs, remediation tickets
Continuity and recovery records	Business continuity plans, recovery plans, backup reports, restoration tests, crisis management exercise reports
Third-party oversight evidence	Supplier register, due diligence records, contracts, service review minutes, assurance reports, exit plans, performance reports
Training records	Completion reports, role-based training materials, awareness communications, phishing simulation results
Assurance records	Internal audit reports, second-line reviews, external assurance, management action plans

Rating Method

Findings were assessed using the following rating approach.

Rating	Description	Management Expectation
Effective	Controls are designed appropriately, implemented, and operating consistently; only minor improvement opportunities identified	Maintain control operation and monitor through normal governance
Largely effective	Controls are generally operating, with limited gaps or inconsistent evidence that do not materially weaken resilience	Remediate through tracked management actions
Partially effective	Control design or operation is incomplete, inconsistent, or not sufficiently evidenced; potential resilience impact if not remediated	Assign priority remediation, monitor at senior management level
Ineffective	Significant weakness in design or operation; material exposure to disruption, regulatory concern, or customer harm	Immediate management action and escalation required

Materiality Considerations

The assessment prioritised matters that could affect:

- Continuity of critical or important functions.
- Integrity, availability, authenticity, or confidentiality of ICT systems and data.
- Timely detection, classification, reporting, and management of major ICT-related incidents.
- Ability to recover services within approved recovery objectives.
- Dependency on ICT third-party providers, including concentration and exit risk.
- Customer outcomes, market integrity, financial stability, or regulatory confidence.
- Accuracy and timeliness of regulatory reporting.

- Management body oversight and accountability.

Detailed Findings / Results (with structure)

1. Governance and Management Accountability

Result

The organisation has established governance arrangements for digital operational resilience. Senior management receives regular reporting on ICT risk, incident trends, resilience testing, third-party ICT risks, and remediation progress. Accountability is assigned across first-line technology and business owners, second-line risk and compliance functions, and independent assurance.

The management body is informed of material ICT risks and receives periodic updates on the DORA implementation programme. The organisation has assigned executive ownership to [Role / Committee], with operational delivery coordinated by [Programme / Function Name].

Evidence Reviewed

Evidence	Status
ICT risk management policy and supporting standards	Reviewed
Digital operational resilience programme plan	Reviewed
Board and risk committee reporting packs	Reviewed
Committee minutes and action logs	Reviewed
Role and responsibility matrix	Reviewed
Management attestations	Reviewed

Observations

- Governance structures are defined and operating, with recurring agenda items for ICT risk and resilience.
- Escalation routes for material incidents and high-rated risks are documented.
- Reporting to senior management includes incident metrics, testing status, control issues, and remediation progress.
- Management information is improving but remains uneven across third-party concentration risk, critical dependency mapping, and ageing of remediation actions.
- Some role accountabilities require clearer documentation where responsibilities are shared between group and local teams.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-01	Board-level reporting does not yet provide a fully integrated view of critical function resilience, third-party dependencies, test outcomes, incidents, and risk appetite metrics in one consolidated dashboard	Medium	[Owner]	[DD MMM YYYY]

Finding ID	Finding	Severity	Owner	Target Date
F-02	Accountability documentation for group-provided ICT services requires further clarification, including local oversight responsibilities and escalation triggers	Medium	[Owner]	[DD MMM YYYY]

2. ICT Risk Management Framework

Result

The organisation maintains an ICT risk management framework that includes identification, assessment, treatment, monitoring, and reporting of ICT risks. ICT risks are recorded in the enterprise risk register and linked to control owners and remediation actions.

Risk assessments are performed for new technology initiatives, material changes, key suppliers, and significant ICT incidents. ICT risk appetite metrics are reported periodically.

Evidence Reviewed

Evidence	Status
ICT risk register	Reviewed
Risk assessment templates and completed assessments	Sampled
Risk treatment plans	Reviewed
Risk acceptance records	Sampled
Risk appetite reporting	Reviewed
Control self-assessments	Sampled

Observations

- ICT risk assessment processes are embedded for major projects and supplier onboarding.
- Risk treatment actions are generally assigned and tracked.
- Risk appetite metrics exist for security events, vulnerabilities, incidents, resilience testing, and supplier assurance.
- Some risks remain open beyond planned due dates due to dependency on technology transformation activities.
- Risk acceptance records do not always include sufficient business rationale, compensating controls, or expiry dates.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-03	Risk acceptance evidence is inconsistent for selected ICT risks, particularly where remediation is deferred due to budget or transformation dependency	Medium	[Owner]	[DD MMM YYYY]

Finding ID	Finding	Severity	Owner	Target Date
F-04	Not all high-rated ICT risks are explicitly mapped to affected critical or important functions	Medium	[Owner]	[DD MMM YYYY]

3. ICT Asset, Service, and Dependency Management

Result

The organisation maintains inventories of ICT assets, applications, infrastructure components, third-party services, and critical business services. Priority systems are identified and assigned business and technical owners.

However, the linkage between ICT assets, business functions, data flows, third-party dependencies, and recovery requirements is not yet complete for all in-scope services.

Evidence Reviewed

Evidence	Status
ICT asset inventory	Reviewed
Application inventory	Reviewed
Critical or important function register	Reviewed
Configuration management data	Sampled
Service dependency maps	Reviewed
Data flow documentation	Sampled

Observations

- Critical applications are known and generally assigned to accountable owners.
- Infrastructure and application inventories are maintained, although reconciliation between tools is not fully automated.
- Mapping between business functions and supporting ICT assets is strongest for customer-facing and transaction-processing services.
- Dependency mapping is less mature for internal reporting platforms, batch processing, data transfer tools, and subcontracted service components.
- Recovery objectives are defined for major platforms but are not always recorded consistently across all inventories.

Rating

Partially effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-05	Critical or important functions are not fully mapped to all supporting ICT assets, data flows, infrastructure components, third-party services, and recovery dependencies	High	[Owner]	[DD MMM YYYY]

Finding ID	Finding	Severity	Owner	Target Date
F-06	Asset inventory records contain inconsistent ownership, criticality, and recovery objective fields for selected systems	Medium	[Owner]	[DD MMM YYYY]

4. ICT Incident Management and Regulatory Reporting

Result

The organisation operates an ICT incident management process covering detection, triage, classification, escalation, communication, resolution, post-incident review, and regulatory assessment.

During the reporting period, [Number] ICT incidents were recorded. Of these, [Number] were assessed as potentially reportable, and [Number] were classified as major ICT-related incidents and reported to the competent authority. All major incidents were subject to post-incident review.

Incident Summary

Incident Category	Number of Incidents	Major Incidents	Primary Causes
Service availability disruption	[Number]	[Number]	[System failure / change error / supplier outage]
Cybersecurity event	[Number]	[Number]	[Phishing / malware / unauthorised access attempt]
Data integrity or processing issue	[Number]	[Number]	[Batch failure / interface error / manual processing defect]
Third-party service disruption	[Number]	[Number]	[Provider outage / network dependency / subcontractor issue]
Identity and access event	[Number]	[Number]	[Privilege error / account misuse / access delay]
Other ICT incident	[Number]	[Number]	[Describe]

Major Incident Reporting Summary

Incident ID	Date Detected	Service Affected	Customer / Business Impact	Regulatory Status	Final Closure Date
[INC-001]	[DD MMM YYYY]	[Service]	[Summary]	Reported	[DD MMM YYYY]
[INC-002]	[DD MMM YYYY]	[Service]	[Summary]	Reported	[DD MMM YYYY]

Observations

- Incident procedures are documented and understood by technology and operational teams.
- Major incident command and escalation arrangements operated effectively.
- Regulatory classification was performed for incidents meeting internal assessment thresholds.
- Post-incident reviews identified root causes and improvement actions.
- Evidence of decision-making for near-threshold incidents should be strengthened to demonstrate why incidents were not reportable.
- Communication templates are available, but scenario-specific customer and authority communications require further refinement.

Rating

Effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-07	Decision records for incidents assessed as non-reportable are not always sufficiently detailed to evidence classification rationale	Low	[Owner]	[DD MMM YYYY]
F-08	Incident communication playbooks should be expanded for multi-jurisdictional and third-party-led incidents	Medium	[Owner]	[DD MMM YYYY]

5. Digital Operational Resilience Testing

Result

The organisation conducted a programme of digital operational resilience testing during the reporting period. Testing included vulnerability assessments, penetration testing, disaster recovery tests, backup restoration, scenario-based exercises, crisis management simulations, and supplier-related resilience reviews.

Testing covered the majority of critical systems and high-risk services. Findings were logged and tracked through remediation governance.

Testing Performed

Test Type	Coverage	Date / Frequency	Result Summary	Open Findings
Vulnerability scanning	[Systems / Coverage]	[Frequency]	[Summary]	[Number]
Penetration testing	[Applications / Infrastructure]	[Date]	[Summary]	[Number]
Disaster recovery test	[Systems]	[Date]	[Summary]	[Number]
Backup restoration test	[Systems / Data sets]	[Date]	[Summary]	[Number]
Cyber incident simulation	[Participants / Scenario]	[Date]	[Summary]	[Number]
Crisis management exercise	[Scenario]	[Date]	[Summary]	[Number]
Third-party resilience test review	[Providers]	[Date]	[Summary]	[Number]
Business continuity exercise	[Functions]	[Date]	[Summary]	[Number]

Observations

- Testing was risk-based and prioritised systems supporting critical or important functions.
- Disaster recovery tests demonstrated recovery capability for [Number] priority systems.
- Backup restoration testing confirmed recoverability for sampled systems and datasets.
- Cyber incident simulation improved cross-functional coordination between technology, legal, compliance, communications, and senior management.
- Test plans and evidence quality varied between teams.

- Retesting of remediated findings is not consistently documented.
- End-to-end scenario testing across multiple providers and business processes remains limited.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-09	Evidence standards for resilience testing are inconsistent, particularly for test entry criteria, exit criteria, actual recovery times, and lessons learned	Medium	[Owner]	[DD MMM YYYY]
F-10	End-to-end testing across critical business services, internal platforms, and third-party ICT providers is not yet sufficiently mature	High	[Owner]	[DD MMM YYYY]
F-11	Retesting evidence for closed technical findings is not consistently retained	Medium	[Owner]	[DD MMM YYYY]

6. Business Continuity, Disaster Recovery, and Crisis Management

Result

Business continuity and disaster recovery arrangements are established for critical services and priority ICT systems. Plans are reviewed periodically and tested through exercises. Crisis management roles are documented, and escalation protocols are in place.

Recovery requirements are generally defined, but the organisation must improve alignment between business impact assessments, technical recovery plans, supplier recovery commitments, and actual test results.

Evidence Reviewed

Evidence	Status
Business impact assessments	Reviewed
Business continuity plans	Sampled
Disaster recovery plans	Sampled
Crisis management plan	Reviewed
Exercise reports	Reviewed
Backup and restoration records	Sampled
Recovery objective records	Reviewed

Observations

- Critical business processes have documented continuity plans.
- Crisis management arrangements are established and tested.
- Disaster recovery tests were completed for key platforms.

- Some recovery plans do not clearly identify manual workarounds, maximum tolerable disruption, recovery sequencing, and interdependencies.
- Supplier recovery commitments are not consistently compared to internal business recovery requirements.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-12	Recovery objectives in business impact assessments, system inventories, and supplier contracts are not consistently aligned	High	[Owner]	[DD MMM YYYY]
F-13	Selected continuity plans require clearer manual workaround procedures and operational decision points	Medium	[Owner]	[DD MMM YYYY]

7. ICT Third-Party Risk Management

Result

The organisation maintains processes for ICT third-party due diligence, contract review, onboarding, ongoing monitoring, performance oversight, risk review, and exit planning. A register of ICT third-party providers is maintained and includes providers supporting critical or important functions.

During the reporting period, [Number] ICT third-party arrangements were reviewed. [Number] were assessed as supporting critical or important functions. [Number] providers were subject to enhanced oversight due to materiality, concentration, performance, cyber risk, or resilience dependency.

ICT Third-Party Register Summary

Category	Number
Total ICT third-party providers recorded	[Number]
Providers supporting critical or important functions	[Number]
Cloud service providers	[Number]
Managed security or managed infrastructure providers	[Number]
Providers with material subcontracting dependencies identified	[Number]
Providers with completed exit plan	[Number]
Providers overdue for annual review	[Number]

Oversight Activities

Activity	Completed	Notes
Initial due diligence for new ICT providers	[Number]	[Summary]
Annual reviews for material ICT providers	[Number]	[Summary]
Contract reviews for critical or important functions	[Number]	[Summary]
Review of assurance reports and certifications	[Number]	[Summary]
Supplier service review meetings	[Number]	[Summary]
Exit plan reviews	[Number]	[Summary]

Activity	Completed	Notes
Concentration risk assessments	[Number]	[Summary]
Subcontractor dependency reviews	[Number]	[Summary]

Observations

- ICT provider register is in place and subject to periodic review.
- Due diligence is performed before onboarding material ICT providers.
- Contracts for critical services generally include provisions for service levels, security obligations, incident notification, audit rights, business continuity, data protection, and termination assistance.
- Ongoing monitoring is performed through service reviews, assurance reports, performance metrics, and risk assessments.
- Exit plans exist for some material providers but are not consistently tested or operationally detailed.
- Concentration risk analysis requires further quantification, particularly for cloud hosting, identity services, managed security services, network providers, and group shared services.
- Visibility of subcontractors and fourth-party dependencies remains incomplete for selected providers.

Rating

Partially effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-14	Exit plans for material ICT providers are not consistently documented, tested, or aligned to recovery priorities	High	[Owner]	[DD MMM YYYY]
F-15	Concentration risk metrics for critical ICT providers require enhancement to support senior management oversight	High	[Owner]	[DD MMM YYYY]
F-16	Subcontractor and fourth-party dependency information is incomplete for selected critical ICT providers	Medium	[Owner]	[DD MMM YYYY]
F-17	Supplier assurance reviews do not consistently document management assessment of exceptions, limitations, or complementary customer responsibilities	Medium	[Owner]	[DD MMM YYYY]

8. Cybersecurity Controls and Threat Management

Result

The organisation operates cybersecurity controls covering identity and access management, network security, endpoint protection, vulnerability management, security monitoring, incident response, data protection, secure configuration, change management, and threat intelligence.

Security operations are supported by [Internal SOC / Managed Security Provider]. Alerts are monitored and escalated under documented procedures. Threat intelligence is used to inform detection, awareness, and vulnerability prioritisation.

Evidence Reviewed

Evidence	Status
Security monitoring reports	Reviewed
Vulnerability management records	Sampled
Access review evidence	Sampled
Privileged access management records	Sampled
Security incident tickets	Sampled
Patch management dashboards	Reviewed
Threat intelligence summaries	Reviewed

Observations

- Security monitoring and escalation arrangements are established.
- Vulnerability scanning is performed on a regular basis.
- Critical vulnerabilities are prioritised for remediation according to severity and exposure.
- Access reviews are conducted for key systems, although evidence quality varies.
- Privileged access controls are in place, with opportunities to strengthen monitoring and recertification.
- Threat intelligence is consumed operationally but should be more formally connected to risk assessments, scenario testing, and board reporting.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-18	Privileged access review evidence is inconsistent for selected systems	Medium	[Owner]	[DD MMM YYYY]
F-19	Threat intelligence outputs are not consistently translated into documented control changes, scenarios, or management reporting	Medium	[Owner]	[DD MMM YYYY]

9. Information Sharing and External Coordination

Result

The organisation participates in selected industry forums, receives threat intelligence from public and private sources, and engages with regulators, law enforcement, sector bodies, and service providers as required.

Formal arrangements for structured cyber threat information sharing are developing. The organisation has not identified any legal or confidentiality barrier preventing responsible participation in relevant information-sharing

activities.

Evidence Reviewed

Evidence	Status
Threat intelligence feeds and reports	Reviewed
Industry forum participation records	Reviewed
Regulatory communication records	Reviewed
Incident coordination records	Sampled
Internal dissemination records	Reviewed

Observations

- Threat information is reviewed by security teams and used in operational monitoring.
- External coordination occurred during relevant incidents and sector alerts.
- There is an opportunity to formalise criteria for sharing indicators, lessons learned, and sector-relevant threat information.
- Legal, compliance, and data protection review steps should be documented for external sharing.

Rating

Developing

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-20	Formal information-sharing procedures require completion, including approval criteria, confidentiality protections, and legal review steps	Low	[Owner]	[DD MMM YYYY]

10. Training, Awareness, and Competence

Result

The organisation delivered ICT risk, cybersecurity, incident management, and operational resilience awareness activities during the reporting period. General cybersecurity awareness training was mandatory for employees and contractors. Targeted training was provided to selected incident responders, system owners, supplier owners, and senior management.

Training Summary

Training Activity	Target Audience	Completion / Attendance	Notes
Annual cybersecurity awareness	All staff and contractors	[Percentage]%	[Summary]
Phishing simulation and awareness	All users	[Percentage]% participation	[Summary]
Incident management training	Incident responders and service owners	[Number] attendees	[Summary]
DORA awareness briefing	Senior management and key control owners	[Number] attendees	[Summary]
Supplier risk management training	Procurement, legal, supplier owners	[Number] attendees	[Summary]

Training Activity	Target Audience	Completion / Attendance	Notes
Crisis management exercise	Crisis team and executives	[Number] attendees	[Summary]

Observations

- Mandatory awareness completion was tracked and escalated.
- Phishing simulation outcomes improved compared with the prior period.
- Role-based training has begun for incident and supplier owners.
- Additional training is required for business owners of critical or important functions, particularly regarding dependency mapping, recovery expectations, incident escalation, and supplier oversight responsibilities.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-21	Role-based resilience training is not yet complete for all critical function owners and supplier relationship owners	Medium	[Owner]	[DD MMM YYYY]

11. Remediation Management and Prior-Period Actions

Result

The organisation maintains a central action tracker for DORA-related findings, ICT risk issues, audit findings, incident lessons learned, supplier actions, and resilience testing observations. Progress is reported to [Committee Name] and escalated where actions are overdue or blocked.

Action Status

Action Category	Open at Start	Raised During Period	Closed During Period	Open at Period End	Overdue
Governance and reporting	[Number]	[Number]	[Number]	[Number]	[Number]
ICT risk management	[Number]	[Number]	[Number]	[Number]	[Number]
Asset and dependency mapping	[Number]	[Number]	[Number]	[Number]	[Number]
Incident management	[Number]	[Number]	[Number]	[Number]	[Number]
Resilience testing	[Number]	[Number]	[Number]	[Number]	[Number]
Third-party risk management	[Number]	[Number]	[Number]	[Number]	[Number]
Cybersecurity controls	[Number]	[Number]	[Number]	[Number]	[Number]
Business continuity and recovery	[Number]	[Number]	[Number]	[Number]	[Number]

Observations

- A central tracker exists and is reviewed regularly.

- High-priority actions are escalated to senior management.
- Closure evidence is retained for most completed actions.
- Some actions have been extended multiple times due to dependency on supplier responses, technology migration, or resource constraints.
- Closure quality criteria should be standardised to ensure that actions are not closed before operating effectiveness is demonstrated.

Rating

Largely effective

Findings

Finding ID	Finding	Severity	Owner	Target Date
F-22	Closure criteria for remediation actions are not consistently defined at the point of action creation	Medium	[Owner]	[DD MMM YYYY]
F-23	Overdue high-priority actions require enhanced executive challenge and documented risk acceptance where delays continue	High	[Owner]	[DD MMM YYYY]

Analysis

Overall Compliance Position

The organisation has implemented the core components required for digital operational resilience. Governance, risk management, incident handling, resilience testing, and third-party oversight are operational and subject to management review. The organisation has demonstrated the ability to identify and respond to ICT incidents, perform resilience testing, maintain continuity arrangements, and oversee key ICT service providers.

The strongest areas are incident management, management engagement, baseline cybersecurity operations, and the existence of structured risk and remediation governance. The principal areas requiring continued investment are dependency mapping, end-to-end resilience testing, third-party concentration management, and evidence quality.

Key Strengths

Strength	Business Value
Established senior governance for ICT risk and resilience	Supports accountability, escalation, and informed decision-making
Operating incident classification and reporting process	Enables timely regulatory assessment and coordinated response
Active resilience testing programme	Provides practical evidence of recovery capability and identifies control weaknesses
Centralised remediation tracking	Improves visibility of risk reduction and management accountability
ICT third-party register in place	Supports oversight of outsourced and cloud-based ICT dependencies
Security monitoring and vulnerability management	Enhances detection, response, and prevention of cyber disruption

Key Risk Themes

1. Incomplete Service and Dependency Mapping

Incomplete mapping between critical or important functions, applications, infrastructure, data flows, suppliers, subcontractors, and recovery dependencies may reduce management's ability to assess impact quickly during incidents or validate end-to-end resilience.

This risk is most relevant where services rely on multiple internal systems, group services, cloud platforms, managed service providers, or batch processing dependencies.

2. Third-Party Concentration and Exit Risk

The organisation relies on several ICT providers for important services. While supplier oversight is in place, further analysis is required to understand concentration across providers, technologies, geographic regions, subcontractors, and group dependencies.

Exit planning should become more operationally detailed, including transition triggers, data portability, alternative service options, timeframes, cost assumptions, and customer impact considerations.

3. Evidence Consistency

Controls are often operating in practice, but evidence is not always retained consistently. This affects resilience testing, risk acceptance, supplier assurance reviews, access reviews, incident classification decisions, and remediation closure.

Improving evidence standards will strengthen internal governance, regulatory reporting readiness, and auditability.

4. End-to-End Resilience Assurance

Individual tests are being performed, but the organisation should increase scenario-based testing across full business services. This includes internal systems, third-party providers, operational teams, communications, data recovery, manual workarounds, and customer impact management.

5. Remediation Ageing

A small number of high-priority actions remain overdue. Although management is aware of these actions, continued delay may increase residual risk if not supported by documented compensating controls, revised risk assessment, and formal acceptance.

Trend Assessment

Area	Trend	Rationale
Governance and accountability	Improving	Regular reporting and executive ownership are established
ICT risk visibility	Improving	Risk register and metrics are maturing
Incident management	Stable / Improving	Process operated effectively during the period
Resilience testing	Improving	Broader testing performed, but end-to-end maturity still developing
Third-party oversight	Stable	Core process exists; concentration and exit planning need enhancement
Asset and dependency mapping	Improving from low baseline	Programme underway but incomplete
Cybersecurity operations	Stable	Key controls operating; privileged access and intelligence integration require improvement
Remediation discipline	Stable	Tracker in place; ageing and closure standards require stronger challenge

Residual Risk View

Based on evidence reviewed, management considers the residual ICT and digital operational resilience risk profile to be within or approaching approved tolerance for most areas, subject to timely completion of the high-priority

actions in this report.

The areas most likely to exceed tolerance if remediation is delayed are:

- Critical dependency mapping.
- Third-party ICT concentration and exit planning.
- Recovery objective alignment across business, technology, and supplier arrangements.
- End-to-end testing of critical services.
- Overdue high-priority remediation actions.

Impact on Customers, Markets, and Regulatory Objectives

No evidence was identified during the reporting period of sustained customer harm, market disruption, or systemic failure arising from ICT disruption. Customer-affecting incidents were managed through established procedures, and material incidents were assessed for regulatory reporting.

The planned improvements are expected to reduce the likelihood and impact of future ICT disruption by improving impact analysis, recovery coordination, supplier resilience, and management decision-making.

Recommendations & Actions

Management Action Plan

The following actions have been approved or proposed to address the findings in this report.

Action ID	Related Finding(s)	Action	Priority	Owner	Target Date	Success Criteria
A-01	F-01	Implement an integrated digital operational resilience dashboard for senior management covering critical functions, incidents, testing, suppliers, risk appetite, and remediation	Medium	[Owner]	[DD MMM YYYY]	Dashboard approved, produced monthly/quarterly, and reviewed by governance forum
A-02	F-02	Clarify local accountability and oversight responsibilities for group-provided ICT services	Medium	[Owner]	[DD MMM YYYY]	Responsibility matrix approved and embedded in reporting and escalation procedures
A-03	F-03	Standardise risk acceptance records for ICT risks, including rationale, expiry date, compensating controls, and senior approval	Medium	[Owner]	[DD MMM YYYY]	Updated template implemented and applied to all high and critical ICT risk acceptances
A-04	F-04, F-05, F-06	Complete mapping of critical or important functions to ICT assets, infrastructure, data flows, third-party services, recovery objectives, and owners	High	[Owner]	[DD MMM YYYY]	Approved dependency maps completed for all critical or important functions

Action ID	Related Finding(s)	Action	Priority	Owner	Target Date	Success Criteria
A-05	F-07	Enhance incident classification records for non-reportable and near-threshold incidents	Low	[Owner]	[DD MMM YYYY]	Classification rationale documented for all assessed incidents
A-06	F-08	Expand incident communication playbooks for customer, regulator, supplier-led, and multi-jurisdictional scenarios	Medium	[Owner]	[DD MMM YYYY]	Playbooks approved and tested in at least one scenario exercise
A-07	F-09, F-11	Define minimum evidence standards for resilience testing and retesting	Medium	[Owner]	[DD MMM YYYY]	Test evidence checklist implemented and used for all priority tests
A-08	F-10	Introduce annual end-to-end scenario testing for selected critical business services involving internal teams and material ICT providers	High	[Owner]	[DD MMM YYYY]	At least [Number] end-to-end tests completed with lessons learned tracked
A-09	F-12, F-13	Align business continuity plans, recovery objectives, technical recovery plans, supplier commitments, and manual workaround procedures	High	[Owner]	[DD MMM YYYY]	Recovery alignment confirmed for all critical or important functions
A-10	F-14	Develop and validate operational exit plans for all material ICT providers supporting critical or important functions	High	[Owner]	[DD MMM YYYY]	Exit plans approved, reviewed, and tested through tabletop or walkthrough
A-11	F-15	Implement third-party ICT concentration risk metrics and reporting	High	[Owner]	[DD MMM YYYY]	Metrics reported to senior governance forum and used in supplier risk decisions
A-12	F-16	Improve subcontractor and fourth-party dependency data collection for critical ICT providers	Medium	[Owner]	[DD MMM YYYY]	Dependency data recorded and reviewed for all material ICT providers
A-13	F-17	Standardise supplier assurance review documentation, including exceptions and complementary responsibilities	Medium	[Owner]	[DD MMM YYYY]	Supplier assurance review template implemented and sampled for quality
A-14	F-18	Strengthen privileged access review evidence and recertification tracking for priority systems	Medium	[Owner]	[DD MMM YYYY]	Reviews completed for all priority systems with exceptions remediated

Action ID	Related Finding(s)	Action	Priority	Owner	Target Date	Success Criteria
A-15	F-19, F-20	Formalise use and sharing of threat intelligence, including legal review, dissemination, and integration with testing and risk assessment	Medium	[Owner]	[DD MMM YYYY]	Procedure approved and evidence of use retained
A-16	F-21	Complete role-based DORA and resilience training for critical function owners, incident leads, system owners, and supplier owners	Medium	[Owner]	[DD MMM YYYY]	Training completion meets [Percentage]% target
A-17	F-22, F-23	Strengthen remediation closure criteria, ageing escalation, and risk acceptance for delayed actions	High	[Owner]	[DD MMM YYYY]	Revised action governance implemented and overdue actions reduced by [Percentage]%

Prioritised Roadmap

Timeframe	Priority Activities
0-3 months	Finalise board dashboard, improve incident classification evidence, standardise risk acceptance, define resilience testing evidence requirements, escalate overdue high-priority actions
3-6 months	Complete critical dependency mapping, align recovery objectives, enhance supplier assurance reviews, improve privileged access evidence, complete role-based training
6-9 months	Implement third-party concentration metrics, complete material provider exit plans, improve subcontractor visibility, perform end-to-end scenario test
9-12 months	Validate remediation effectiveness, perform second end-to-end resilience scenario, update annual reporting evidence pack, refresh maturity assessment

Management Commitments

Management commits to:

- Maintain active oversight of the action plan through [Committee Name].
- Provide progress updates to [Board / Management Body Name] at least [Monthly / Quarterly].
- Escalate overdue high-priority actions and obtain documented risk acceptance where delays materially affect resilience.
- Retain evidence supporting action closure, including testing or independent validation where appropriate.
- Notify the competent authority of material developments where required.
- Incorporate lessons learned from incidents, testing, audits, supplier reviews, and regulatory feedback into the resilience framework.

Requested Regulatory Engagement

[Organisation Name] welcomes feedback from the competent authority on this report and is available to provide supporting evidence, walkthroughs, or further clarification upon request.

The organisation proposes the following engagement points, if considered useful by the competent authority:

Topic	Proposed Engagement
DORA implementation progress	Review meeting with compliance, ICT risk, and resilience leads
Major ICT incidents	Walkthrough of incident classification and reporting evidence
Third-party ICT risk	Discussion of concentration and exit planning improvement programme
Resilience testing	Review of annual testing plan and end-to-end scenario approach
Remediation plan	Periodic update on high-priority action closure

Distribution & Confidentiality

Distribution

This report is approved for distribution to the designated competent authority and the internal stakeholders listed below.

Recipient / Group	Purpose
[Competent Authority Name]	Regulatory reporting and supervisory review
[Board / Management Body Name]	Approval, oversight, and accountability
[Executive Committee / Risk Committee]	Management monitoring and action ownership
[Chief Executive Officer]	Executive accountability
[Chief Information Officer]	ICT control and remediation ownership
[Chief Information Security Officer]	Cybersecurity and incident management ownership
[Chief Risk Officer]	ICT risk oversight and risk appetite monitoring
[Chief Compliance Officer]	Regulatory compliance and submission oversight
[Head of Procurement / Third-Party Risk]	Supplier oversight and remediation ownership
[Internal Audit]	Independent assurance planning and follow-up
[Legal / Data Protection Officer]	Legal, confidentiality, and data protection support

Confidentiality Classification

This report is classified as **Confidential - Regulatory Submission**.

It contains sensitive information regarding ICT systems, security controls, incidents, third-party dependencies, resilience capabilities, vulnerabilities, remediation plans, and management assessments. Unauthorised disclosure could expose the organisation to operational, security, commercial, legal, or regulatory risk.

Handling Requirements

Recipients must:

- Use the report only for regulatory, governance, assurance, or remediation purposes.
- Not forward, copy, publish, or disclose the report externally without approval from [Chief Compliance Officer / Legal Counsel], except where required by law or regulatory instruction.
- Store the report in approved secure repositories with access restricted to authorised personnel.
- Protect any extracts, summaries, or supporting evidence to the same confidentiality level as the report.
- Avoid including sensitive technical details in wider distribution materials unless necessary and approved.
- Report any suspected unauthorised disclosure to [Security / Compliance Contact] immediately.

Supporting Evidence

Supporting evidence for this report is retained by [Function / Repository Name] and may be provided to the competent authority upon request through controlled channels.

Evidence Pack	Custodian	Location / Repository	Retention Period
Governance evidence	[Owner]	[Repository]	[Retention Period]
ICT risk evidence	[Owner]	[Repository]	[Retention Period]
Incident evidence	[Owner]	[Repository]	[Retention Period]
Resilience testing evidence	[Owner]	[Repository]	[Retention Period]
Third-party oversight evidence	[Owner]	[Repository]	[Retention Period]
Remediation evidence	[Owner]	[Repository]	[Retention Period]
Training evidence	[Owner]	[Repository]	[Retention Period]
Assurance evidence	[Owner]	[Repository]	[Retention Period]

Approval

Role	Name	Approval Date	Signature / Record
[Board Chair / Management Body Representative]	[Name]	[DD MMM YYYY]	[Reference]
[Chief Executive Officer]	[Name]	[DD MMM YYYY]	[Reference]
[Chief Risk Officer]	[Name]	[DD MMM YYYY]	[Reference]
[Chief Information Officer]	[Name]	[DD MMM YYYY]	[Reference]
[Chief Information Security Officer]	[Name]	[DD MMM YYYY]	[Reference]
[Chief Compliance Officer]	[Name]	[DD MMM YYYY]	[Reference]